

A website can only access its own database, XSS breaks this rule.

Cross Site Scripting (XSS)

Script = mostly JavaScript.

Date:

↓
Attacker writes a bad script. The script ends up running inside a trusted site.

Types of XSS

- ① Stored XSS Attack
- ② Reflected XSS Attack.

① Stored XSS Attack. (Bad code stored on website and attacks every visitor)

- Attacker puts bad javascript into a website
- Website saves it
- Later, when normal users visit page, website send code to them
- Browser runs the code automatically.

② Reflected XSS (Comes from the link. Nothing is saved on the server)

↓
Click → instant
link attack.

• Echoed Input (• website takes user input. • displays it back on the page)

Defense is (sanitizing).

(Browser poisoned)

XSS

• Attacker controls what website sends to your browser

- Runs JavaScript
- Steals data
-

CSRF

(Website is tricked)

Attacker controls what your browser sends to the website.

No JavaScript.
Forces action